

H

IMPLEMENTATION AUDIT

Pre-launch audit — hardikajmeriya.com

Date: 6 September 2026

Build audited: commit `bf6d62e` **Verdict: Not yet — three things block launch, and none of them are code.**
See [the answer](#) at the end.

What I could and could not measure

This matters more than any individual finding, so it goes first.

Measured directly, by building the site and inspecting the output:

- every byte in `dist/`, per file, gzipped and raw
- the exact critical-path weight and which requests block first paint
- contrast ratios computed from the real hex values, not eyeballed
- the prerendered DOM: heading order, landmarks, `alt`, `width / height`, meta tags
- 68 automated tests across the Worker
- ESLint across the project
- clamp arithmetic against each named viewport width

Not measured — and I will not pretend otherwise:

ITEM YOU ASKED FOR	STATUS
Lighthouse scores	Not run. Chrome's download host is unreachable from my sandbox. I can tell you which audits will pass and why, but I have no score to report, and inventing one would be worse than useless
LCP / CLS / TBT field values	Not measured. These need a real browser. I have measured their inputs and fixed the ones that were wrong
Safari / Firefox / Edge rendering	Not tested. No browser available
Visual rendering at each breakpoint	Not viewed. Reviewed as arithmetic against the CSS, which catches overflow but not ugliness

Where I say "this will fail Lighthouse", it is because the audit has a deterministic rule I checked against the DOM — not because I ran it.

Summary

	COUNT
🔴 Must fix before launch	3

	COUNT
⚠ Fixed during this audit	24
⚠ Needs improvement, not blocking	9
✅ Already correct	14

❓ MUST FIX — these block launch

1. Every project links to a dead end · CRITICAL

All four projects have `liveUrl: ''`. One (`dcpvas`) also has `githubUrl: ''`, so **that card has no working link at all**.

The site's entire argument is "I don't just write code, I put it in production." Four projects, zero live URLs, is the exact claim the page makes and then fails to evidence. A client checking your work finds nothing to click.

I removed the `Live site – add URL` placeholder from the public build — it was being rendered to visitors, which read as an unfinished site. But hiding the placeholder does not create the evidence. **This is a content problem only you can fix.**

The cheapest fix that unblocks launch: deploy **one** project — CureNeed is furthest along — and link it. One live URL is worth more than four polished screenshots.

2. GitHub contradicts the pitch · CRITICAL

I fetched the profile the site links to. It says:

Android & DevOps Enthusiast — Building seamless mobile experiences with clean architecture

Pinned repositories: `AndroidStudioWebApp`, `SQL-Pizza-Sales`, `Titanic-Data-Analysis`, `CI-CD-Pipeline`. Three followers. **None of the four portfolio projects are pinned.**

Every "Source code →" button sends a prospective client from a page selling senior full-stack MERN work to a profile advertising something else. That inconsistency does more damage than a slow LCP ever will.

Twenty minutes of work: rewrite the bio, pin the four portfolio repos, add `hardikajmeriya.com` to the profile website field.

One more thing to decide before launch: the `MedCare` README credits **two authors — Anshuman Singh and Hardik Ajmeriya**. The portfolio presents CureNeed without mentioning collaboration. A client who clicks through sees the co-author. Say "built with" on the card; shared credit costs you nothing and being caught omitting it costs a lot.

3. Three different email addresses across your properties · HIGH

WHERE	ADDRESS
Portfolio + <code>llms.txt</code> + JSON-LD	<code>hardik.ajmeriya89@gmail.com</code>
GitHub profile README	<code>hardik.ajmeriya12@gmail.com</code> , and a <code>hardik@example.com</code> placeholder
Admin panel / Cloudflare	<code>hardikpt95@gmail.com</code>

Pick one business address and use it everywhere. Consistent contact details are a ranking signal for a personal-name entity, and — more practically — a client who mails the wrong one gets no reply. The `hardik@example.com` placeholder on your GitHub README is a live broken link right now.

⚠️ FIXED DURING THIS AUDIT — 24 items

Deploy weight

1. **29 MB of unreferenced images were being deployed · HIGH** `public/images/` held 13 PNG/JPGs that nothing referenced — including `hero_pic.jpg` at **11 MB**. Everything in `public/` is copied verbatim into `dist/` , so all of it was uploaded and publicly fetchable. The `.webp` conversions had been made; the originals were never removed. Moved to `assets-original/` (gitignored, not deployed). **dist: 31 MB → 2.2 MB.**

2. **170 KB of legacy `.woff` fallbacks · LOW** — stripped at build time. No browser since 2016 requests them.

Critical path

3. **Google Fonts sat in front of the largest text on the page · HIGH** Two extra origins and, worse, a sequential round trip: fetch CSS from `googleapis` , parse it, only then fetch files from `gstatic` . Now self-hosted and served from the same warm connection as the HTML.

4. **No font preloading · MEDIUM** — `prerender.js` now injects `<link rel="preload">` for Bricolage 800 (the `h1` — your LCP element) and Inter 400, reading the hashed filenames from the build so they cannot go stale.

5. **Google Fonts removed from the CSP · LOW** — two fewer trusted origins, and it removes the only request that sent a visitor's IP to Google before they interacted with anything.

Correctness and credibility

6. **The footer said "Deployed on AWS" · HIGH** — it's Cloudflare. On a portfolio whose pitch is that the deployment half is done properly, this is the one factual error a technical client is most likely to check. Now correct.

7. Four public "Live site — add URL" placeholders · HIGH — a note-to-self rendered to visitors. Now development-only.

8. `x.com/REPLACE-WITH-YOUR-HANDLE` in JSON-LD `sameAs` · MEDIUM — a URL that 404s in `sameAs` weakens the entity rather than strengthening it. Removed.

9. LinkedIn missing from the footer · MEDIUM — it was in the structured data but not on the page, and it is currently your best-ranking property.

10. Every unknown URL returned 200 with the homepage · MEDIUM `not_found_handling` was `single-page-application` — correct for an app with a client-side router, and this site has none. `/pricing`, `/blog`, `/wp-admin` all answered 200 with the full homepage. Google calls that a soft 404 and reads an unbounded set of duplicate URLs as a quality signal against the site. Now a real 404 page with a real status code.

11. Meta description was 177 characters · LOW — truncated at ~160, which cut off "Available for freelance projects" — the part that asks for the business. Now 151.

Accessibility — measured, not assumed

12. `accent2` as text: 1.74:1 · HIGH — "In active development" was effectively unreadable. Added an `accent2Text` token at 4.84:1; the bright green stays on the decorative dot.

13. `muted` on hover backgrounds: 4.42:1 · MEDIUM — just under AA. `#6b6b73` → `#5c5c64`, now 6.01:1 on paper and 5.54:1 on the hover state.

14. Mockup browser-chrome text: 2.45:1 · LOW — darkened.

15. No focus-visible styles anywhere outside the form · HIGH — the site relied on the browser default, which is near-invisible against this palette and fully suppressed inside the `mix-blend-difference` navbar. Added a global `:focus-visible` ring. Mouse users see nothing change.

16. No skip link · MEDIUM — WCAG 2.4.1. Added, plus `id="main"`.

17. Mobile menu could not be closed with a keyboard · MEDIUM — no Escape handler on a full-screen overlay. Added, with `aria-controls`.

18. Touch targets below 44px · MEDIUM — the hamburger was 28×24, the tech filters ~38px, footer links ~18px. All now ≥44px with no visual change.

19. Screen readers announced the marquee twice · LOW — the duplicated copy that makes the loop seamless is now `aria-hidden`.

Layout stability and motion

20. None of the 38 images declared dimensions · HIGH — the direct cause of Cumulative Layout Shift, and lazy loading made it more likely, not less. All 38 now carry `width / height`, including the 34 third-party logos.

21. Project frames cropped every screenshot · LOW — sources are 1536×1024 (3:2), the frame was 16:10, so `object-cover` silently trimmed a strip off the bottom of all four. Frame now matches the source exactly.

22. `min-h-screen` on the hero · MEDIUM — `100vh` on mobile is the height with browser chrome hidden, so the hero overflowed by the height of the address bar and the layout jumped as it collapsed. Now `100svh`.

23. The headline overflowed at 320px · MEDIUM — `clamp()` floor of 3.2rem is wider than a 320px viewport can hold for the unbreakable word "production.", and `overflow-x: hidden` on `body` meant it was clipped rather than scrolled — silent. Floor lowered to 2.35rem.

24. Tilt cards ran forever · MEDIUM — each project kept a `requestAnimationFrame` loop running for the whole visit, on- or off-screen, hovered or not. Four permanent loops writing transforms nobody was looking at: Total Blocking Time and battery for nothing. Now paused via `IntersectionObserver`, matching what `HeroCanvas` already did.

Bonus — the site was invisible without JavaScript. Every `.rv` element starts at `opacity: 0` and the hero is translated out of its clipping box; both are revealed by JS. If the bundle failed, the visitor got a fully-populated DOM rendering as a blank page. Added a `@media (scripting: none)` fallback.

Security

25. No server-side rate limiting · HIGH — you asked for this explicitly. The cooldown lived in `Contact.jsx`, in the browser, in a variable an attacker controls. It stops a double-click. It does not stop `curl` in a loop.

New `worker/rateLimit.js` + migration `0002`, with 14 tests:

BUCKET	LIMIT
Per IP	5/hour, 15/day
Per recipient address	3/hour, 6/day
Site-wide	40/day

The per-recipient bucket is the important one and it was not on your list. The auto-reply is sent to whatever address the `submitter` types. Without a cap on that, **anyone could make `hardikajmeriya.com` send repeated mail to a stranger** — an open relay. The damage lands on your sending reputation and outlives the attack.

The site-wide cap is arithmetic, not a guess: Resend's free plan allows 100 emails/day and each submission sends two, so 40 submissions = 80 emails. There is a test asserting this stays true if anyone changes the number.

It fails open — the opposite of `worker/access.js`, deliberately. Losing a real enquiry because a counter table is unavailable is worse than admitting some spam; exposing client data is worse than locking yourself out. Different trade-off, different direction.

Addresses and IPs are stored as salted SHA-256, never in the clear. There is a test asserting no raw value ever reaches the table.

Also corrected: `AUTOREPLY.md` claimed you would need 100 enquiries in a day to exhaust the free tier. Each submission sends two emails, so the real ceiling is 50.

⚠️ NEEDS IMPROVEMENT — not blocking

#	ISSUE	PRIORITY
1	three.js is 170 KB gzipped for a decorative hero. It is code-split, gated off mobile and reduced-motion, and never blocks paint — but on desktop it is still 684 KB to parse. The 150 orbiting nodes are 150 separate <code>Mesh</code> objects = 150 draw calls per frame; <code>InstancedMesh</code> or <code>Points</code> would cut that to one	Medium
2	34 technology logos load from <code>cdn.jsdelivr.net</code> — a third-party origin on the page, with an <code>onError</code> fallback if it is blocked. Self-hosting the ~34 SVGs would remove the dependency entirely	Medium
3	Stats render as 0 in the prerendered HTML — the count-up starts at zero, so an AI crawler reading the static HTML sees "0 Projects built end-to-end". Render the final value and animate from it	Medium
4	Collapsed FAQ answers stay readable to screen readers — deliberate, so crawlers see them, but a screen-reader user hears every answer regardless of state. <code>inert</code> when closed would give you both	Medium
5	No privacy policy , and you now store personal data in D1 — names, emails, briefs, country codes. Also decide a retention period; "deleted after 24 months" is defensible, indefinite is not	Medium
6	<code>sitemap.xml</code> <code>lastmod</code> says 2026-09-02 — stale after these changes	Low
7	FAQ JSON-LD is hand-copied from <code>faq.js</code> — two sources that have already drifted once. Generate it at build time	Low
8	<code>dcpvas.dev</code> shown in a mockup address bar for a project with no live site. <code>argocd.internal</code> and <code>grafana.local</code> are honestly internal-looking; a <code>.dev</code> domain implies something real	Low
9	CSP allows <code>static.cloudflareinsights.com</code> but no analytics script is installed — either add Web Analytics or drop the origin	Low

✅ ALREADY CORRECT

Credit where it is due — these were right before I touched anything:

1. **Prerendering.** 9,205 characters of visible text in the static HTML. No major AI crawler runs JavaScript; without this they would index `<div id="root"></div>`
2. **Heading hierarchy** — exactly one `h1`, no skipped levels across 30 headings
3. **Landmarks** — `nav`, `main`, `footer`, sectioned correctly
4. `script-src` **has no** `unsafe-inline` **and no** `unsafe-eval` — the directive that actually matters for XSS. `unsafe-inline` on `style-src` only, and genuinely required
5. **Every SQL query parameterised**, including the `LIKE` search

6. **CSV export neutralises formula injection** — `= + - @` prefixed
7. **Admin auth verifies the signed JWT**, not the forgeable header, and fails closed
8. **Email header injection blocked** by the control-character filter
9. **Server-side validation mirrors the client** and is the real gate
10. **Honeypot returns success** so bots learn nothing
11. **A database failure still sends the email** — losing a lead is worse than losing a row
12. `HeroCanvas` **disposes geometries, materials and the renderer**, and pauses off-screen
13. **Cache headers are correct** — immutable for hashed assets, revalidate for HTML
14. `robots.txt` **explicitly allows AI crawlers by name** — the right call for being cited

Verification

```
npm run build          ✓ dist 2.2 MB, prerender 9,205 chars, 2 fonts preloaded
worker/index.test.mjs ✓ 15 passed
worker/admin.test.mjs ✓ 39 passed
worker/rateLimit.test.mjs ✓ 14 passed
npx eslint .           ✓ 0 problems
34-point DOM assertion ✓ 34/34
```

	BEFORE	AFTER
<code>dist</code> total	31 MB	2.2 MB
Images shipped	29.5 MB	0.40 MB
Third-party origins on the critical path	2	0
Images without dimensions	38	0
WCAG AA text-contrast failures	3	0
Touch targets under 44px	3	0
Public TODO placeholders	4	0
Server-side rate limiting	none	3 buckets
Worker tests	54	68

Before you deploy

```
cd app
npx wrangler d1 migrations apply hardik-enquiries --remote # rate_limits table
npx wrangler secret put RATE_LIMIT_SALT # optional
npm run deploy
```

The migration is not optional — without the table the limiter logs an error and fails open on every request, which is safe but leaves you unprotected.

Would you confidently launch this portfolio publicly today?

No — but the reasons have nothing to do with the code.

The engineering is in good shape. It is prerendered, the security model is sound and now genuinely tested, the critical path is 66 KB from a single origin, and the things that were wrong were mostly invisible-until-measured: contrast a shade too light, a `clamp()` floor that clipped rather than scrolled, a rendering loop nobody could see running.

What stops me is that **the site makes a specific claim it cannot currently back up**. It says: *most developers hand you a repository and stop; I hand you a running application*. Then it shows four projects, none of which link to a running application, and sends you to a GitHub profile that describes a different person doing different work.

A client will notice that in about forty seconds, and no Lighthouse score compensates for it.

Launch when these three are true:

1. At least one project has a live URL. One is enough — it converts the central claim from an assertion into evidence.
2. The GitHub profile matches the pitch: bio rewritten, the four repos pinned, website link added.
3. One business email address everywhere, and the `hardik@example.com` placeholder gone from your GitHub README.

Realistically an afternoon. Item 1 is the only one with any real work in it, and you are a deployment engineer — deploying CureNeed is a Tuesday.

Do those three and I would launch it without hesitation. The site is good. It just needs to be able to prove the thing it is claiming.